

CISSP Printable Practice Exam 01 - Domain 1 - Security and Risk Management

Domain 1

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP1-001)

Scenario: A security manager learns that an executive intends to conceal a serious weakness in a public transportation control environment until after a pending financing announcement. The weakness could expose passengers to physical harm, and the executive orders the manager to remain silent.

Which consideration should guide the security manager's response FIRST?

- A. Protecting the employer's financing strategy and confidential business plans
- B. Advancing the security profession by publishing technical details of the weakness
- C. Protecting society and public safety through appropriate escalation and lawful action
- D. Following the executive's instruction until an internal audit confirms the weakness

Question 2 (CISSP1-002)

Scenario: Before approving a new customer platform, a board committee requests an asset inventory, reviews applicable obligations, examines threat information, and commissions a risk assessment. Management will select and operate safeguards after reviewing the results.

The committee's actions MOST directly demonstrate which concept?

- A. Due diligence, because decision-makers are systematically identifying and evaluating risk
- B. Due care, because the selected safeguards are already operating effectively
- C. Risk transfer, because the assessment shifts accountability to the assessors
- D. Non-repudiation, because the committee can prove that the review occurred

Question 3 (CISSP1-003)

Scenario: A manufacturer is expanding a time-sensitive distribution service. Executives believe the security program produces many technical reports but does not show whether it supports the expansion strategy.

What should the CISO do FIRST to improve security governance?

- A. Increase the number of vulnerability findings reported each month
- B. Map security objectives and risk measures to the expansion's business goals and risk appetite
- C. Require every business unit to use identical technical safeguards
- D. Delegate acceptance of strategic security risk to the operations team

Question 4 (CISSP1-004)

A digital approval process must establish that a message came from the claimed sender and provide strong evidence that the sender cannot credibly deny approving it. Which 2 security properties address these requirements? Select 2 of the 5 options below.

- A. Availability
- B. Authenticity
- C. Confidentiality
- D. Non-repudiation
- E. Fault tolerance

Question 5 (CISSP1-005)

Scenario: A retail enterprise identifies a residual risk in an order-processing service after reasonable safeguards are applied. The security office documented the exposure, but the service owner wants the security analyst to accept the risk on behalf of the business.

Who should normally make the risk acceptance decision?

- A. The security analyst who performed the assessment
- B. The external assessor who confirmed the residual risk
- C. The business owner with authority and accountability for the affected service
- D. The system administrator responsible for implementing safeguards

Question 6 (CISSP1-006)

Scenario: An organization plans to acquire a smaller firm whose systems will be connected to the parent network immediately after closing. The target has not used the parent's security control framework.

Which action should security leadership recommend as the HIGHEST priority before integration?

- A. Perform risk-based security due diligence and define remediation or integration conditions
- B. Replace every target system before assessing its business importance
- C. Delay all security review until ownership legally transfers
- D. Accept the target's risks because the acquisition sponsor approved the transaction

Question 7 (CISSP1-007)

Scenario: A government prosecutor alleges that an individual intentionally committed a computer offense prohibited by statute. A conviction could result in imprisonment.

Which legal category and general standard of proof apply?

- A. Civil law and proof by clear organizational policy
- B. Criminal law and proof beyond a reasonable doubt
- C. Administrative law and proof beyond all possible doubt
- D. Contract law and proof by technical consensus

Question 8 (CISSP1-008)

Scenario: A university's policy states that sensitive information must be protected. Security leadership now needs a mandatory organization-wide document specifying minimum authentication settings that can be tested consistently.

Which type of document should contain these detailed mandatory requirements?

- A. Guideline
- B. Procedure
- C. Standard
- D. Mission statement

Question 9 (CISSP1-009)

Scenario: During an authorized administrative investigation, an investigator finds evidence suggesting deliberate financial fraud. Management believes law enforcement may become involved, but no referral has yet been made.

What is the BEST next action?

- A. Continue informal interviews until the suspected employee confesses
- B. Immediately publish the findings to warn other employees
- C. Preserve evidence under documented procedures and consult legal counsel about

escalation

D. Delete unrelated evidence so the investigation file remains concise

Question 10 (CISSP1-010)

An organization wants to protect both its distinctive product logo and a confidential manufacturing method that derives value from remaining secret. Which 2 forms of intellectual property protection are MOST directly applicable? Select 2 of the 5 options below.

- A. Copyright for the confidential manufacturing method
- B. Trademark for the distinctive product logo
- C. Trade secret protection for the confidential manufacturing method
- D. Patent protection automatically created without filing or disclosure
- E. Software license protection for the product logo

Question 11 (CISSP1-011)

Scenario: A global services company intends to move personal data from customers in one jurisdiction to a processing center in another. The project team argues that encryption alone makes legal review unnecessary.

What should the privacy and security leaders do FIRST?

- A. Approve the move because encryption eliminates jurisdictional obligations
- B. Determine applicable transfer restrictions, lawful mechanisms, contracts, and data-location requirements
- C. Copy all data to the new location and assess obligations after operations stabilize
- D. Treat the move solely as an internal technical architecture decision

Question 12 (CISSP1-012)

Scenario: A travel company discovers that customer records may have been accessed without authorization. Affected customers reside in several jurisdictions, and the facts are still developing.

Which action is MOST appropriate at this stage?

- A. Wait for complete certainty before activating any breach process
- B. Notify every possible authority immediately using an unverified incident count
- C. Activate the incident and legal assessment process, preserve facts, and track applicable notification deadlines
- D. Let the technical team decide whether legal notification is necessary

Question 13 (CISSP1-013)

An illustrative risk analysis estimates a single loss expectancy of \$80,000 and an annualized rate of occurrence of 0.25. What is the annualized loss expectancy?

- A. \$20,000
- B. \$32,000
- C. \$80,000
- D. \$320,000

Question 14 (CISSP1-014)

Scenario: A media firm considers offering a service in a region where the required operating model would exceed the firm's approved risk appetite. Leadership decides not to launch the service there.

Which risk treatment strategy has leadership selected?

- A. Acceptance
- B. Avoidance

- C. Mitigation
- D. Transfer

Question 15 (CISSP1-015)

Scenario: After a mitigation project, the residual risk to a clinical scheduling service remains above the approved tolerance. The service manager's delegated acceptance authority covers only risks within tolerance, and suspending the service could disrupt patient care.

What should the service manager do NEXT?

- A. Accept the risk because mitigation has already been attempted
- B. Alter the risk rating so it falls within delegated authority
- C. Escalate the decision with treatment options and business-impact information to an authorized risk owner
- D. Immediately suspend the service without consulting business continuity stakeholders

Question 16 (CISSP1-016)

During STRIDE threat modeling, the team identifies an attacker impersonating a trusted service account and separately changing a transaction while it is stored. Which 2 STRIDE categories correspond to these threats? Select 2 of the 5 options below.

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Information disclosure
- E. Denial of service

Question 17 (CISSP1-017)

Scenario: A logistics company is selecting a provider that will process sensitive shipment and customer data. Procurement has compared price and features but has not assessed security or included security terms in the draft agreement.

What should the security manager recommend BEFORE contract execution?

- A. Rely on the provider's marketing statement as evidence of adequate security
- B. Perform a risk-based assessment and add measurable security, notification, audit, and service requirements
- C. Accept all provider risk because outsourcing transfers accountability
- D. Wait for the first service review to determine whether contractual requirements are needed

Question 18 (CISSP1-018)

Scenario: A financial cooperative maintains a risk register, but senior leaders receive only a quarterly count of open technical findings. They cannot tell whether exposure is rising, whether treatment is late, or whether risk is approaching tolerance limits.

Which improvement would provide the MOST useful risk oversight?

- A. Report trends in key risk indicators, residual risk, treatment status, ownership, and tolerance breaches
- B. Replace risk reporting with a complete list of raw event logs
- C. Report only findings that have already caused a confirmed loss
- D. Remove accepted risks from all future monitoring

Question 19 (CISSP1-019)

Scenario: A regional wholesaler is updating its continuity program. Technology teams want to purchase recovery services immediately, but the organization has not identified critical

processes, dependencies, outage impacts, or acceptable recovery timeframes.

What should the continuity manager do FIRST?

- A. Select the recovery service with the shortest advertised restoration time
- B. Conduct a business impact analysis with process owners
- C. Copy the disaster recovery plan used by the largest business unit
- D. Ask technology teams to assign priorities based only on system cost

Question 20 (CISSP1-020)

Scenario: A privileged database administrator will be involuntarily terminated at a scheduled meeting tomorrow. Human resources has notified security under an approved confidential process.

Which plan BEST reduces risk while supporting a controlled termination?

- A. Disable access at a coordinated time, recover organizational assets, preserve needed records, and remind the employee of continuing obligations
- B. Disable access now without coordinating with human resources or the administrator's manager
- C. Leave access active for several days so the employee can answer follow-up questions
- D. Delete the administrator's account and all associated activity records during the meeting

Question 21 (CISSP1-021)

Scenario: An engineering firm gives every worker the same annual security awareness presentation. Developers continue to introduce preventable security defects, even though completion rates are high.

Which change is MOST likely to address the weakness?

- A. Increase the length of the same general presentation for all employees
- B. Add role-based secure development training with practical exercises and outcome measures
- C. Measure success only by whether employees opened the presentation
- D. Replace training with a policy requiring defect-free software

Question 22 (CISSP1-022)

Scenario: A research organization will give temporary contractors access to confidential project information. The engagement lasts three months and access should end immediately when each assignment concludes.

Which 2 controls are MOST important to establish for this engagement? Select 2 of the 5 options below.

- A. Risk-appropriate screening and signed confidentiality terms before access is granted
- B. Documented sponsorship, access expiration, and prompt offboarding tied to the assignment end date
- C. Permanent access so returning contractors can resume work quickly
- D. An informal verbal agreement that replaces written security requirements
- E. A single shared account to simplify contractor administration

Question 23 (CISSP1-023)

Scenario: A billing process becomes unacceptable to the business after 12 hours of disruption. The continuity team sets a target to restore the supporting service within 8 hours, leaving time for validation and process recovery.

How should the 8-hour target be interpreted?

- A. It is the recovery time objective, set shorter than the maximum tolerable downtime
- B. It is the annualized rate of occurrence for the disruption
- C. It is the recovery point objective for allowable data loss
- D. It is proof that the process will always recover within 8 hours

Question 24 (CISSP1-024)

Scenario: A public utility reports that 99 percent of personnel completed required awareness content. Its board asks whether the program actually reduces human-related risk rather than merely documenting attendance.

Which measurement approach would BEST answer the board's question?

- A. Track only annual completion percentages because completion proves behavioral change
- B. Compare role-relevant simulations, incident trends, reporting behavior, and targeted knowledge results over time
- C. Count the number of slides included in each awareness course
- D. Ask course authors whether they believe the material is effective

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP1-001) - Correct: C

The duty to protect society, the common good, and public trust has priority when credible physical harm is possible. Appropriate escalation and lawful reporting address that duty without unnecessarily disclosing sensitive technical details. Protecting the employer is important but does not override public safety, immediate publication could create additional risk, and waiting for an audit would leave a serious known exposure untreated.

Question 2 (CISSP1-002) - Correct: A

Due diligence is the ongoing process of investigating, understanding, and evaluating risk before and during decision-making. Due care is demonstrated by taking reasonable protective action based on that knowledge, which occurs later in this scenario. An assessment does not transfer accountability, and a record of the review alone does not establish non-repudiation of business transactions.

Question 3 (CISSP1-003) - Correct: B

Effective governance begins by aligning security objectives, priorities, and measures with business goals and approved risk appetite. More vulnerability counts may add operational data without demonstrating strategic value. Uniform safeguards can ignore differing business risks, and operational personnel should not be assigned acceptance authority for strategic risk unless governance has explicitly granted it.

Question 4 (CISSP1-004) - Correct: B, D

Authenticity supports confidence that the message and sender are genuine, while non-repudiation provides evidence intended to prevent a party from successfully denying an action. Confidentiality limits disclosure, availability concerns timely access, and fault tolerance supports continued operation; none of those three directly satisfies both stated approval requirements.

Question 5 (CISSP1-005) - Correct: C

Risk acceptance belongs to the accountable business owner or another properly authorized decision-maker who understands the business consequences. Security analysts advise and document, assessors provide independent findings, and administrators implement controls. Those roles do not normally own the business impact or possess delegated authority to accept it.

Question 6 (CISSP1-006) - Correct: A

Pre-integration due diligence reveals inherited exposure, legal obligations, control gaps, and conditions that should influence the acquisition and integration plan. Wholesale replacement before assessment is not risk-based. Waiting until after transfer sacrifices the opportunity to establish conditions, while deal approval does not itself constitute informed acceptance of unidentified security risk.

Question 7 (CISSP1-007) - Correct: B

A government prosecution for a statutory offense that can lead to imprisonment is criminal, and the prosecution generally must prove guilt beyond a reasonable doubt. Civil disputes commonly use a lower standard such as preponderance of the evidence. Administrative matters depend on the governing regime, and neither organizational policy nor technical consensus is a legal standard of proof.

Question 8 (CISSP1-008) - Correct: C

A standard translates high-level policy into specific, mandatory, and measurable

requirements. A procedure gives step-by-step instructions for performing a task, while a guideline offers recommended flexibility. A mission statement expresses broad organizational purpose and is not the appropriate vehicle for testable authentication settings.

Question 9 (CISSP1-009) - Correct: C

Potential criminal proceedings require disciplined evidence preservation, documented handling, and coordination with legal counsel so investigative authority and referral obligations are respected. Informal questioning may compromise the investigation, publication can violate confidentiality and due process, and deleting material before lawful relevance and retention decisions are made can damage evidentiary integrity.

Question 10 (CISSP1-010) - Correct: B, C

Trademark law is designed to protect source-identifying marks such as a distinctive product logo. A valuable confidential method can qualify as a trade secret when reasonable measures preserve its secrecy. Copyright does not protect a functional method itself, patent rights are not created automatically, and a software license is not the relevant protection for a brand logo.

Question 11 (CISSP1-011) - Correct: B

Cross-border processing must be evaluated against the laws, transfer mechanisms, contractual commitments, and location restrictions that apply to the data and jurisdictions involved. Encryption can reduce risk but does not eliminate legal duties. Moving first creates avoidable exposure, and classifying the change as purely technical ignores governance and privacy requirements.

Question 12 (CISSP1-012) - Correct: C

The organization should promptly activate coordinated incident, privacy, and legal assessment; preserve reliable facts; determine affected jurisdictions; and manage applicable deadlines. Waiting for perfect certainty may cause missed obligations, while premature unverified notices can be inaccurate. Notification decisions require authorized legal and business input, not an isolated technical determination.

Question 13 (CISSP1-013) - Correct: A

Annualized loss expectancy equals single loss expectancy multiplied by annualized rate of occurrence: $\$80,000 \times 0.25 = \$20,000$. The other values result from using an incorrect operation or treating the expected frequency as if one loss occurred every year. ALE is an estimate used to compare risk and treatment costs, not a guarantee of actual loss.

Question 14 (CISSP1-014) - Correct: B

The firm avoids the risk by choosing not to undertake the activity that would create the exposure. Acceptance would retain the risk, mitigation would reduce its likelihood or impact while continuing the activity, and transfer would shift defined financial consequences through a contract or insurance without removing organizational accountability.

Question 15 (CISSP1-015) - Correct: C

Residual risk above tolerance must be escalated to someone authorized to decide whether to add treatment, change the activity, or formally approve an exception. A prior mitigation attempt does not create acceptance authority, and changing the rating would undermine governance. Immediate suspension may itself create serious business harm and should be evaluated by accountable stakeholders unless an emergency mandate requires it.

Question 16 (CISSP1-016) - Correct: A, B

Impersonating a trusted identity is spoofing, while unauthorized modification of stored

transaction data is tampering. Repudiation concerns denying an action, information disclosure concerns unauthorized exposure, and denial of service concerns loss or degradation of availability. Those categories do not directly describe the two behaviors stated.

Question 17 (CISSP1-017) - Correct: B

Due diligence before signing should evaluate the provider's risk and convert important expectations into enforceable, measurable contract and service terms. Marketing claims are insufficient evidence. Outsourcing may allocate certain obligations or financial consequences, but the customer retains accountability for managing its risk. Post-contract review is too late to negotiate essential protections effectively.

Question 18 (CISSP1-018) - Correct: A

Decision-makers need contextual, trend-based information showing residual exposure, accountable owners, treatment progress, and movement toward or beyond tolerance. Raw logs are too operational for enterprise oversight, confirmed losses are lagging and incomplete indicators, and accepted risk must still be monitored because assumptions and conditions can change.

Question 19 (CISSP1-019) - Correct: B

A business impact analysis identifies critical activities, dependencies, consequences of disruption, and recovery requirements so strategies can be selected rationally. Buying a solution first may misalign cost and capability. Reusing one unit's plan ignores enterprise differences, and system cost alone does not reveal business criticality or acceptable downtime.

Question 20 (CISSP1-020) - Correct: A

A coordinated termination synchronizes access revocation with the meeting, recovers assets, preserves evidence and business records, and reinforces confidentiality or other surviving obligations. Premature unilateral revocation can disrupt the planned process, delayed access creates avoidable exposure, and deleting records can harm operations, investigations, and retention compliance.

Question 21 (CISSP1-021) - Correct: B

General awareness builds broad recognition, while developers need role-based knowledge and practiced skills tied to their responsibilities. Practical exercises and outcome measures can reveal whether behavior and capability improve. A longer generic presentation does not address the skill gap, opening content is not evidence of learning, and policy alone cannot build competence.

Question 22 (CISSP1-022) - Correct: A, B

Risk-appropriate screening and enforceable confidentiality terms establish trust and obligations before access. Sponsorship, defined expiration, and prompt offboarding limit access to the authorized engagement. Permanent access violates least privilege, verbal arrangements provide weak governance, and shared accounts undermine accountability and controlled revocation.

Question 23 (CISSP1-023) - Correct: A

The recovery time objective is the planned target for restoring a service after disruption and should support recovery before the maximum tolerable downtime is reached. Annualized rate of occurrence is a risk-frequency estimate. Recovery point objective measures tolerable data loss in time, and an objective is a planning requirement rather than a guarantee of actual performance.

Question 24 (CISSP1-024) - Correct: B

A combination of behavioral, operational, and knowledge measures tracked over time provides stronger evidence that awareness changes actions and reduces risk. Completion is useful for compliance but does not prove effectiveness. Content volume is not an outcome, and author opinion lacks the objective evidence needed for governance decisions.